Guía de Actividades Práctico-Experimentales Nro. 001

1. Datos Generales

Asignatura	Software Security
Ciclo	8 A
Unidad	1
Resultado de Aprendizaje de la Unidad	R1. Diseña e implementa software bajo los principios básicos de estándares seguros, en el marco de los principios de solidaridad, transparencia, responsabilidad y honestidad.
Práctica Nro.	1 (Fases 1 a 4)
Título	Análisis y superficie de ataque del proyecto
Docente	Valeria Herrera Salazar
Período	Del 28 de septiembre al 23 de octubre de 2026 (Semanas 1 a 4)
Horario	Jueves: 09h30 – 11h30 Viernes: 07h30 – 09h30
Lugar	Aula de Clase
Tiempo planificado	16 horas (4 horas por semana)

(Abarca APE 1, 2, 3 y 4 - Semanas 1 a 4)

2. Objetivo(s) de la Práctica:

La primera guía inicia el proyecto integrador que acompañará a toda la asignatura: cada estudiante o pareja de trabajo selecciona la aplicación que auditará durante las dieciséis semanas y construye, sobre ella, la línea base de seguridad del proyecto. Cada fase responde de manera directa al contenido teórico tratado en las horas de contacto con el docente de esa misma semana.

- Seleccionar la aplicación que se auditará durante las dieciséis semanas del ciclo (un proyecto propio de asignaturas anteriores o un entorno controlado como DVWA u OWASP Juice Shop).
- Delimitar la superficie de ataque de la aplicación y elaborar el inventario inicial de elementos expuestos.
- Aplicar la tríada CIA (confidencialidad, integridad y disponibilidad) para clasificar los activos y las amenazas del proyecto.
- Revisar la gestión de errores y excepciones, detectando las fugas de información en mensajes y trazas de la aplicación.
- Evaluar la aplicación frente al OWASP Top 10 y elaborar la matriz de priorización de hallazgos que servirá de insumo directo para la auditoría técnica de la guía APE 02.

Firmado electrónicamente por:
EDISON LEONARDO CORONEL ROMERO
Validar únicamente con FirmaEC

3. Materiales y reactivos:

Los recursos necesarios para esta guía están disponibles en la infraestructura institucional y en herramientas de libre acceso. El docente publicará en el EVA, con anticipación a cada semana, las plantillas de registro correspondientes a cada fase.

- Ordenador personal con acceso a internet y navegador web actualizado.
- Cuenta activa en GitHub u otra plataforma similar para el repositorio de evidencias del proyecto (una cuenta por pareja o por estudiante).
- Aplicación objetivo: proyecto propio de asignaturas previas (con código disponible, ejecución local, autenticación y base de datos) o entorno controlado (DVWA u OWASP Juice Shop) instalado en una máquina virtual.
- Plantillas del EVA: ficha del proyecto, inventario de superficie de ataque, matriz de activos y amenazas, registro de gestión de errores y lista de cotejo OWASP Top 10.
- Material de consulta: la entrada oficial del OWASP Top 10 y los documentos de clase de las semanas 1 a 4.

4. Equipos y herramientas:

- Aula física con equipamiento audiovisual.
- Computadoras personales o dispositivos móviles de los estudiantes.
- Entorno Virtual de Aprendizaje (EVA) de la UNL.
- Repositorio GitHub del proyecto para el portafolio de evidencias.
- Software de hojas de cálculo (Excel/Google Sheets) para la matriz de activos y amenazas y para la matriz de priorización de hallazgos.
- Procesador de texto para la redacción de los informes de cada fase.

5. Procedimiento / Metodología:

Nota: *Esta guía se desarrolla en ocho sesiones de dos horas cada una (Semanas 1 a 4), los jueves de 09h30 a 11h30 y los viernes de 07h30 a 09h30. Cada semana corresponde a una fase de la práctica y comprende dos sesiones consecutivas.*

Fase 1 (Semana 1 - del 28 de septiembre al 02 de octubre de 2026): Encuadre del componente práctico y selección de la aplicación objetivo

Sesión 1 (jueves 01 de octubre, 09h30 a 11h30): Organización y exploración de candidatos

Actividad 1: Socialización de la organización del componente APE (25 minutos)

El docente presenta la organización del componente práctico experimental: las cuatro guías del ciclo, sus fases, los entregables, las rúbricas y su incidencia en la calificación del componente. Se socializa además el cronograma de las dieciséis semanas y el enfoque de proyecto integrador continuo que acompaña a toda la asignatura.

Actividad 2: Diagnóstico práctico inicial (20 minutos)

Los estudiantes resuelven un cuestionario breve e individual sobre conceptos fundamentales de seguridad (tríada CIA, tipos de vulnerabilidades y superficies de exposición), aplicado mediante una actividad del EVA. Los resultados permiten al docente identificar los conceptos que requerirán refuerzo durante la unidad.

Actividad 3: Exploración de candidatos a aplicación objetivo (45 minutos)

Cada pareja revisa sus proyectos de asignaturas anteriores conforme a los requisitos mínimos definidos (código disponible, ejecución local, autenticación y base de datos) o verifica la instalación del entorno controlado (DVWA u OWASP Juice Shop) en una máquina virtual. Se registra la viabilidad de cada candidato como base de la decisión final.

Actividad 4: Registro del proyecto (30 minutos)

Las parejas crean el repositorio de GitHub del proyecto con la estructura de carpetas por guía y fase, y redactan la primera versión de la ficha del proyecto: nombre, función, usuarios, roles y tecnologías empleadas.

Sesión 2 (viernes 02 de octubre, 07h30 a 09h30): Puesta en marcha e inventario inicial

Actividad 1: Confirmación de criterios y alcance (15 minutos)

De manera conjunta se verifica que la aplicación seleccionada cumple los requisitos mínimos y se delimita por escrito lo que se auditará durante el ciclo: módulos, funcionalidades y datos dentro del alcance del proyecto.

Actividad 2: Puesta en marcha del entorno (40 minutos)

Los estudiantes instalan o ejecutan localmente la aplicación, crean los usuarios de prueba (administrador y usuario común) y verifican el acceso a las funcionalidades principales. Se documentan las versiones y los componentes utilizados como referencia de las fases posteriores.

Actividad 3: Inventario inicial de la superficie de ataque (45 minutos)

Mediante un recorrido guiado, las parejas registran las páginas, formularios, parámetros de URL, endpoints y funcionalidades expuestas de la aplicación, con capturas de pantalla como evidencia de cada elemento inventariado.

Actividad 4: Cierre y consolidación (20 minutos)

Se consolida el inventario en la plantilla del EVA, se cargan las evidencias al repositorio y se define el compromiso de trabajo para la siguiente fase.

Fase 2 (Semana 2 - del 05 al 09 de octubre de 2026): Tríada CIA y matriz de activos y amenazas

Sesión 1 (jueves 08 de octubre, 09h30 a 11h30): Activos de información y clasificación CIA

Actividad 1: Repaso aplicado de la tríada CIA (20 minutos)

El docente conduce un repaso de la confidencialidad, la integridad y la disponibilidad, la defensa en profundidad y los tipos de atacantes, retomando los ejemplos de fallos históricos de seguridad analizados durante la semana en el foro del EVA.

Actividad 2: Construcción de la matriz de activos (70 minutos)

Trabajo guiado: las parejas llenan la matriz de activos de su aplicación (datos almacenados, datos en tránsito, servicios y credenciales), clasifican cada activo frente a los tres pilares de la tríada e identifican al menos una amenaza por activo. El docente acompaña la clasificación de los activos que generen duda.

Actividad 3: Revisión entre pares (30 minutos)

Las parejas intercambian sus matrices y elaboran retroalimentación escrita sobre activos faltantes o clasificaciones discutibles, que se incorpora al documento antes del cierre de la sesión.

Sesión 2 (viernes 09 de octubre, 07h30 a 09h30): Controles y priorización

Actividad 1: Defensa en profundidad (25 minutos)

Identificación de las capas de control presentes en la aplicación (autenticación, validación de entrada, cifrado y respaldo) y de las capas ausentes, con base en el inventario y la matriz de la sesión anterior.

Actividad 2: Propuesta de controles de mitigación (65 minutos)

Para cada activo crítico, las parejas proponen dos controles de mitigación con una justificación breve de su elección, vinculando cada control con el pilar de la tríada que protege.

Actividad 3: Informe de la fase (30 minutos)

Elaboración del informe parcial en la plantilla del EVA y carga del documento y de la matriz de activos en el repositorio del proyecto.

Fase 3 (Semana 3 - del 12 al 16 de octubre de 2026): Gestión de errores y fugas de información

Sesión 1 (jueves 15 de octubre, 09h30 a 11h30): Provocación controlada de errores

Actividad 1: Marco conceptual (20 minutos)

El docente explica qué información sensible revelan los mensajes de error (trazas de pila, versiones de componentes, rutas de archivos y consultas) y por qué estas revelaciones constituyen una fuga de información utilizable por un atacante.

Actividad 2: Laboratorio de provocación de errores (80 minutos)

Cada pareja provoca de forma controlada al menos cinco errores en su aplicación (credenciales inválidas, parámetros alterados, recursos inexistentes, formularios incompletos y subida de archivos fallida) y registra en la plantilla la información expuesta en cada caso, con captura de pantalla como evidencia.

Actividad 3: Sistematización de hallazgos (20 minutos)

Consolidación de las fugas detectadas en el registro de la fase y preparación de la clasificación que se realizará en la siguiente sesión.

Sesión 2 (viernes 16 de octubre, 07h30 a 09h30): Clasificación y corrección

Actividad 1: Buenas prácticas de gestión de errores (15 minutos)

Revisión de las buenas prácticas del desarrollo seguro: mensajes genéricos orientados al usuario, registro detallado en el servidor (logs) y deshabilitación del modo de depuración en producción.

Actividad 2: Clasificación y corrección de fugas (85 minutos)

Las parejas clasifican la severidad de cada fuga detectada y redactan la versión corregida del mensaje correspondiente; cuando el código de la aplicación está disponible, implementan la corrección en el componente respectivo y documentan el cambio realizado.

Actividad 3: Informe de la fase (20 minutos)

Redacción del informe de gestión de errores y carga de las evidencias en el repositorio del proyecto.

Fase 4 (Semana 4 - del 19 al 23 de octubre de 2026): Mapeo OWASP Top 10 y priorización de hallazgos

Sesión 1 (jueves 22 de octubre, 09h30 a 11h30): Lista de cotejo OWASP

Actividad 1: Repaso del OWASP Top 10 (25 minutos)

Repaso de las diez categorías de riesgo con ejemplos de cada una, con énfasis en las categorías tratadas durante la semana: XSS, CSRF y exposición de datos.

Actividad 2: Aplicación de la lista de cotejo (75 minutos)

Laboratorio guiado: aplicación de la lista de cotejo OWASP Top 10 sobre la aplicación (mecanismos de sesión, tokens CSRF, cabeceras de seguridad, políticas de contraseñas, exposición de datos y componentes con vulnerabilidades conocidas), registrando la evidencia de cada ítem verificado.

Actividad 3: Registro de evidencias (20 minutos)

Sistematización de los resultados por categoría en la plantilla de la guía, con la conclusión fundamentada de cada una.

Sesión 2 (viernes 23 de octubre, 07h30 a 09h30): Priorización y cierre de la guía

Actividad 1: Matriz de priorización (20 minutos)

Construcción de la matriz de impacto y probabilidad con los hallazgos de las cuatro fases y selección de los tres hallazgos más relevantes del proyecto.

Actividad 2: Preparación del insumo para la guía APE 02 (70 minutos)

Completar la matriz con evidencias y estructurar la información que pasará a la auditoría técnica de la guía APE 02: criptografía, control de acceso e inyecciones. Cada pareja verifica que su repositorio contiene los entregables de las cuatro fases.

Actividad 3: Cierre y socialización (30 minutos)

Redacción del informe consolidado de la guía y socialización breve de los tres hallazgos prioritarios de cada pareja, con retroalimentación del docente y del curso.

6. Resultados esperados:

- Repositorio del proyecto en GitHub constituido, con la ficha del proyecto y el inventario de superficie de ataque con evidencias.
- Matriz de activos y amenazas clasificada según la tríada CIA, con controles propuestos para los activos críticos.
- Informe de gestión de errores con las fugas documentadas, su severidad clasificada y las correcciones propuestas.
- Lista de cotejo OWASP Top 10 completada con evidencias y matriz de priorización de los hallazgos del proyecto.
- Línea base del proyecto de seguridad consolidada, primer componente del portafolio que sustentará la defensa final de la semana 16.

7. Preguntas de Control:

1. La superficie de ataque de una aplicación web no se limita a sus páginas visibles: incluye formularios, parámetros, cabeceras y componentes de terceros. ¿Por qué un inventario exhaustivo de la superficie de ataque constituye el punto de partida de cualquier auditoría de seguridad, y qué riesgos implica omitir un componente del inventario?
2. Al clasificar los activos con la tríada CIA, un mismo activo puede exigir controles distintos para la confidencialidad, la integridad y la disponibilidad. ¿Cómo determinaría usted qué pilar priorizar cuando los recursos son limitados? Justifique su respuesta con un ejemplo de su propio proyecto.
3. Los mensajes de error detallados facilitan la depuración durante el desarrollo, pero constituyen una fuga de información en producción. ¿Qué prácticas permiten conciliar ambas necesidades, y qué información concreta no debería revelar jamás un mensaje de error dirigido al usuario final?
4. El OWASP Top 10 es un documento de concientización, no un estándar de verificación. ¿Qué relación existe entre sus diez categorías de riesgo y las vulnerabilidades concretas observadas en su aplicación, y por qué la priorización de hallazgos debe considerar el impacto y la probabilidad, y no únicamente la severidad técnica?

8. Evaluación:

Rúbrica de Evaluación (10 puntos)

Criterio	Excelente (2.5)	Bueno (1.5)	Regular (0.5)	Deficiente (0)
1. Selección y alcance del proyecto (Fase 1)	La aplicación seleccionada cumple todos los requisitos, ejecuta localmente y el repositorio con la ficha y el inventario de superficie de ataque está completo y organizado.	La aplicación cumple los requisitos con observaciones menores; repositorio completo con detalles de forma pendientes.	Aplicación con requisitos parciales o inventario con menos de cinco elementos documentados.	Sin aplicación funcional o sin repositorio de evidencias.
2. Tríada CIA y matriz de activos (Fase 2)	Matriz con seis o más activos, clasificación CIA correcta por activo y controles coherentes con las amenazas identificadas.	Matriz completa con observaciones menores de clasificación o de controles.	Matriz con menos de cuatro activos o clasificación confusa entre los pilares.	Sin matriz de activos o sin clasificación CIA.
3. Gestión de errores (Fase 3)	Cinco o más fugas documentadas con evidencia, severidad clasificada y correcciones conforme a las buenas prácticas.	Tres o cuatro fugas documentadas o correcciones genéricas.	Menos de tres fugas documentadas o evidencias incompletas.	Sin informe de gestión de errores.
4. Mapeo OWASP Top 10 (Fase 4)	Lista de cotejo completa con conclusión fundamentada por categoría y matriz de priorización justificada.	Lista con vacíos menores de verificación o priorización poco justificada.	Lista parcial o sin evidencias de verificación.	Sin lista de cotejo ni matriz de priorización.
5. Documentación, evidencias y ética	Evidencias claras y trazables en el repositorio; trabajo realizado exclusivamente en el entorno propio o controlado.	Evidencias con observaciones de formato; cumplimiento de las reglas éticas del laboratorio.	Evidencias insuficientes o desordenadas.	Evidencias ausentes o prácticas fuera del entorno autorizado.

Nota: La Actividad Práctico–Experimental podrá ser utilizada por el docente con carácter demostrativo. En tal caso, tanto la calificación como la entrega del Reporte Técnico por parte de los estudiantes pueden ser opcionales.

9. Bibliografía:

- Haz Lopez, L. V., et al. (2024). Hacking Ética: Teoría y Prácticas. CID. ISBN: 978-1-967344-23-9.
- Vega Briceño, E. (2021). Seguridad de la Información. Editorial Área de Innovación y Desarrollo. ISBN: 978-84-122093-6-5.
- Whitman, M. E., & Mattord, H. J. (2018). Management of Information Security (6th ed.). Cengage Learning.

- OWASP Foundation. (2025). OWASP Top 10. Recuperado de https://owasp.org/Top10/
- Howard, M., & LeBlanc, D. (2003). Writing Secure Code (2nd ed.). Microsoft Press.

10. Elaboración y Aprobación:

Elaborado por	Valeria Herrera Salazar **Docente**	Validar únicamente en FirmaEC. Firmado electrónicamente por: VALERIA DEL ROSARIO HERRERA SALAZAR
Revisado por *Solo si es realizado en laboratorios*	**Técnico Docente**	
Aprobado por	Edison L. Coronel Romero **Director de Carrera**	